CrankMart - Product Requirements Document

Version: 2.0 (Production Draft) **Date:** 2026-04-11 **Status:** In Review **Owner:** Lew Hofmeyr (COO / Product) **Audience:** Engineering, Design, QA, DevOps, Stakeholders **Methodology:** CDDP (CTO Deliberative Development Protocol)

Document Control

Version	Date	Author	Changes
1.0	2026-04-11	CTO	Initial draft (high-level)
2.0	2026-04-11	CTO	Production rewrite: personas, user stories, API contracts, flows, threat model, migration runbook, testing strategy

Related Documents

- `docs/API_CONTRACTS.md` -- Full API reference (91+ endpoints)
- `docs/REBRAND_INVENTORY.md` -- 950+ change locations for rebrand/i18n
- `IMPLEMENTATION_GUIDE.md` -- 31-step implementation roadmap

Table of Contents (Full PRD)

Part 1 (this document): Executive Summary, Problem Statement, Personas, Success Metrics **Part 2:** Functional Requirements with User Stories, Feature Inventory, Data Model **Part 3:** User Flows, Security Threat Model, Privacy & Compliance, Testing Strategy **Part 4:** Migration Runbook, Release Criteria, Monitoring, Feature Flags, Risks, Glossary

---

1. Executive Summary

1.1 What CrankMart Is

CrankMart is the international evolution of CycleMart.co.za, a production-grade cycling community platform combining:

- **Classifieds marketplace** (2,000+ listings target)

- **Business directory** (bike shops, brands, service centres, tour operators, event organisers)
- **Cycling routes library** (500+ SA routes from Trailforks/Komoot/MTB Trails SA)
- **Events calendar** (races, sportives, rides, training camps)
- **Community messaging** (buyer-seller direct chat)
- **News & editorial**

Built on Next.js 16 + Neon Postgres + Vercel + Drizzle ORM, with PayFast (SA) and future Stripe (international) payments.

1.2 Why We're Rebuilding

Driver	Detail
Rebrand	CycleMart -> CrankMart (new domain, brand, social, email)
International scalability	Phased rollout: SA -> AU -> NZ -> UK -> EU -> US
Stack modernisation	Move from self-hosted velo-server to Neon + Vercel serverless
Infrastructure simplification	Decommission nginx, systemd, manual uploads; adopt Vercel Blob, edge CDN
Architectural foresight	Country-agnostic framework at crankmart.com root with per-country verticals at /za, /au, /nz

1.3 Strategic Outcomes (12-month horizon)

- crankmart.com live globally with /za as the first country vertical
- SA user base migrated from cyclemart.co.za (301 redirects preserve SEO)
- Australia launched (Phase 2) using the same framework
- 99.9% uptime, sub-2.5s LCP, Lighthouse 90+ across all pages
- R25,000+ monthly recurring revenue from SA boost packages
- Foundation laid for Stripe + multi-locale expansion

1.4 CDDP Alignment

This PRD was produced following the CDDP protocol: Review -> Research -> Scope -> Spec -> Cross-Reference -> Integration Assessment -> Suggest/Ask/Advise -> Request to Execute. Every requirement is justified by user need, market data, or existing code (documented in Part 2's cross-reference column).

---

2. Problem Statement

2.1 The Problem

For South African cyclists: There is no single trusted destination combining bike classifieds, local shop discovery, trail information, events, and community. Options today:

Current	Problem
BikeHub.co.za	Classifieds only; no routes, events, or directory; dated UX
Gumtree, Facebook Marketplace	No cycling focus; low trust; no search/filter by bike specs
Facebook Groups (MTB SA, etc.)	No structure, no search, scam risk, poor discovery
Strava	Training/routes only; no marketplace, no directory
BuyCycle.com	International; no SA payment, no SA routes, no local community

Gap: SA cyclists juggle 4-6 platforms. Discovery is fractured. Trust is low. Sellers lose money to scams. Shops can't reach buyers efficiently. Event organisers rely on Facebook and email.

2.2 The Opportunity

SA cycling market:

- Estimated 500K+ active cyclists
- Strong MTB culture (Cape Epic, sani2c, Wines2Whales)
- Growing road cycling segment
- Established bike shop network (400+ shops)
- Active event calendar (150+ events/year)

International market (future phases):

- Australia: ~2M regular cyclists, strong MTB culture, no dominant all-in-one
- New Zealand: ~500K cyclists, world-class trail networks, underserved
- UK: mature but fragmented (BikeRadar, Sell My Bike, eBay)
- EU / US: massive addressable market, Stripe-native

CrankMart's edge:

All-in-one (marketplace + directory + routes + events + community)

Local payment (PayFast for SA, Stripe for international)

Trust layer (verified businesses, moderated listings, KYC, POPIA/GDPR compliant)

Content moat (curated routes + events = massive SEO surface)

Monetisation from day one (boost packages, tiered business subscriptions)

International framework (single codebase, country modules)

2.3 Business Case

Metric	Year 1 Target (SA)	Year 3 (SA + AU + NZ)
Registered users	10,000	100,000
Active listings	3,000	25,000
Directory businesses	400	2,500
Monthly recurring boost revenue	R25,000 (~$1,350)	$50,000
Marketplace GMV	R15M (~$815K)	$15M
Organic monthly visitors	25,000	400,000

Unit economics: Boost packages (R149-R999/month), business tiers (R0-R999/month), future: transaction fees, featured placement, sponsored content.

---

3. Target Users & Personas

3.1 Persona: Sibu -- The Private Seller

- **Role:** Hobbyist MTB cyclist, Cape Town
- **Age:** 34
- **Goals:** Sell his Specialized Stumpjumper to upgrade; reach serious buyers, avoid scammers
- **Pain points:** Facebook Marketplace is full of lowballs; doesn't want to pay R500 Gumtree fees
- **Needs:** Easy listing flow, photo upload, price guidance, in-app messaging, buyer verification
- **Success:** Lists in <5 min, sells in 14 days, pays 0 commission
- **Maps to:** Sell flow (steps 1-4), listing renewal, messaging, boost-for-visibility

3.2 Persona: Thandi -- The Buyer

- **Role:** New cyclist looking for first real bike, Johannesburg
- **Age:** 28
- **Goals:** Find a reliable hardtail under R15,000 near her
- **Pain points:** Doesn't know what specs matter; worried about buying a stolen bike

- **Needs:** Filter by discipline/price/location, clear condition grading, seller reputation, WhatsApp contact
- **Success:** Finds bike in 3-5 searches, messages seller, meets safely
- **Maps to:** Browse, search, filters, listing detail, contact seller, saved listings

3.3 Persona: Marco -- The Bike Shop Owner

- **Role:** Owner of Marco's Cycles (independent shop), Stellenbosch
- **Age:** 48
- **Goals:** Drive walk-in traffic, promote new stock, build online presence
- **Pain points:** Google ranking poor; Facebook reach declining; can't afford full digital agency
- **Needs:** Business profile, brand/service listings, boosted placement, analytics, claim existing listing
- **Success:** Claims his listing, upgrades to Pro tier (R399/mo), gets 50+ directory views/week
- **Maps to:** Directory, business claim flow, my-shop dashboard, boost packages, verification

3.4 Persona: Kagiso -- The Event Organiser

- **Role:** Volunteer organiser of Soweto Cycle Festival
- **Age:** 41
- **Goals:** Maximise entries, reach cyclists across Gauteng
- **Pain points:** Relies on WhatsApp groups and posters; low repeat attendance
- **Needs:** Event submission, calendar visibility, map view, boosted listing option, edit link
- **Success:** Event listed, 300+ views, 50+ entries vs last year's 20
- **Maps to:** Event submission, organiser portal, token-based edit flow, event boost

3.5 Persona: Zanele -- The Admin / Platform Operator

- **Role:** CrankMart operations
- **Age:** 32
- **Goals:** Moderate content, verify businesses, track payments, spot abuse
- **Pain points:** Fraudulent listings, unverified businesses, payment disputes
- **Needs:** Admin dashboard, moderation queues, KYC workflow, payment reconciliation, analytics, SEO audits, email template management
- **Success:** <4h listing moderation SLA, <48h business verification, 0 unresolved PayFast disputes
- **Maps to:** All /admin/* pages (17 pages), verification pipeline, boost admin, email templates, settings

3.6 Persona Priority Matrix

Persona	Phase 1 Priority	Rationale
Sibu (Seller)	P0	Listings are core inventory
Thandi (Buyer)	P0	Buyers drive seller activity
Marco (Shop Owner)	P1	Directory drives SEO + revenue
Kagiso (Organiser)	P1	Events drive recurring traffic
Zanele (Admin)	P0	Platform can't operate without moderation

---

4. Market Analysis & Competitive Positioning

4.1 South African Market

Competitor	Strengths	Weaknesses	CrankMart Counter
BikeHub.co.za	Established brand, classifieds traffic	Dated UX, classifieds only, no mobile-first	Modern UX, all-in-one, mobile-first
Gumtree SA	Scale	No cycling focus, low trust, paid listings	Cycling-specific filters, free listings, trust system
Facebook Groups	Community	No search, no structure, scam risk	Structured, searchable, moderated
Strava	Routes + fitness	No marketplace, no directory	Marketplace + local community

4.2 International Positioning

Once expanded to AU/NZ/UK, CrankMart competes with:

- BikeExchange (AU), BuyCycle (EU), PinkBike Buy/Sell (MTB), eBay Motors
- **Differentiator:** All-in-one community + marketplace, not just listings

4.3 Defensible Moats

SEO moat: 500+ route pages + 400+ business pages + events = massive long-tail content

Network effects: More listings -> more buyers -> more sellers (flywheel)

Trust layer: POPIA/GDPR compliant, verified businesses, moderated content, KYC

International framework: Launch new country in 4-6 weeks via config, not rebuild

Data moat: Bike specs, prices, routes, events -- proprietary dataset over time

---

5. Success Metrics & KPIs

5.1 North Star Metric

Monthly Active Contributors (MAC) -- users who list, message, review, or save in a given month. Target Phase 1 (SA): 2,000 MAC by month 6.

5.2 Launch Metrics (First 30 days, SA)

Metric	Target	Measurement
crankmart.com live	Day 1	Uptime monitor
cyclemart.co.za 301 -> crankmart.com/za	Day 1	curl check
Lighthouse Performance	>= 90	Vercel Speed Insights
Zero P0 bugs in production	100%	Sentry tracking
All existing users migrated	100%	DB row count match

5.3 Phase 1 Growth Metrics (Months 1-6, SA)

Metric	Month 1	Month 3	Month 6
Registered users	500	2,000	5,000
Active listings	300	1,000	2,000
Directory businesses	100	200	400
Verified businesses	20	80	200
Monthly page views	5K	15K	30K
Monthly organic visitors	2K	6K	10K
Boost revenue/mo (R)	2,000	10,000	25,000
Email list	200	600	1,000

5.4 International Expansion Metrics (per new country, 6-month)

Metric	Target
Registered users	2,000
Active listings	500
Directory businesses	50
Routes seeded at launch	200+
Events seeded at launch	30+
Boost revenue/mo (local currency)	$1,000 equiv

5.5 Non-Functional KPIs

KPI	Target	Measurement
Uptime	99.9%	Vercel + UptimeRobot
API p95 latency	< 500ms	Vercel analytics
LCP	< 2.5s	Speed Insights
CLS	< 0.1	Speed Insights
Lighthouse Accessibility	>= 95	CI check
Error rate	< 0.5%	Sentry
Mean time to recovery (MTTR)	< 30 min	Incident log

5.6 Business KPIs

KPI	Phase 1 Target	How Measured
GMV (marketplace turnover)	R15M/yr	Sum of sold listing prices
Take rate	0% (boosts only)	N/A in Phase 1
Boost conversion	5% of active listings	Boosts / active listings
Business tier upgrade	15% of verified	Paid / verified
Organic traffic share	60%+	Google Analytics
Net Promoter Score	40+	Post-transaction survey

End of Part 1

Part 2A: Feature Inventory

Carried forward from CycleMart v0.2.1 and enhanced. Each feature has a status, owner persona, phase priority, and cross-reference to existing code.

6. Feature Inventory

6.1 Authentication & User Management

ID	Feature	Status	Persona	Priority	Code Reference
F-AUTH-01	Email/password login	Exists	All	P0	src/auth.ts:18-46
F-AUTH-02	Google OAuth login	Exists	All	P0	src/auth.ts:14-17
F-AUTH-03	Email verification	Schema exists, not wired	All	P1	users.emailVerified
F-AUTH-04	Password reset (email token)	Exists	All	P0	app/api/auth/forgot-password
F-AUTH-05	Session management (JWT)	Exists	All	P0	src/auth.ts:53
F-AUTH-06	Role-based access (7 roles)	Exists	Admin	P0	userRoleEnum
F-AUTH-07	KYC workflow	Schema exists, UI pending	Seller/Shop	P2	users.kycStatus
F-AUTH-08	Profile editing (name, province, password)	Exists	All	P0	/api/account/update
F-AUTH-09	Avatar upload	Exists	All	P1	/api/account/avatar

ID	Feature	Status	Persona	Priority	Code Reference
F-AUTH-10	Account deletion (POPIA/GDPR)	**New**	All	P1	Schema + DELETE /api/account

6.2 Classifieds Marketplace

ID	Feature	Status	Persona	Priority	Code Reference
F-LIST-01	Browse listings (filters, pagination)	Exists	Buyer	P0	app/browse/page.tsx
F-LIST-02	Listing detail page	Exists	Buyer	P0	app/browse/[slug]/ListingDetail.tsx
F-LIST-03	4-step sell wizard	Exists	Seller	P0	app/sell/step-1..4
F-LIST-04	Draft autosave (server + localStorage)	Exists	Seller	P0	/api/sell/draft
F-LIST-05	Multi-image upload (up to 15, 10MB each)	Exists	Seller	P0	/api/sell/upload
F-LIST-06	Bike-spec fields (brand, model, year, frame, wheels, drivetrain)	Exists	Seller	P0	listings table
F-LIST-07	Condition grading (new/like_new/used/poor)	Exists	Seller	P0	conditionEnum
F-LIST-08	Price + negotiable flag	Exists	Seller	P0	listings.price/negotiable
F-LIST-09	Shipping availability	Exists	Seller	P1	listings.shippingAvailable
F-LIST-10	Duplicate detection on publish	Exists	Seller	P0	publish route
F-LIST-	Edit own listing	Exists	Seller	P0	/api/listings/by-id/[id]/edit

ID	Feature	Status	Persona	Priority	Code Reference
11					
F-LIST-12	Mark as sold	Exists	Seller	P0	/api/listings/[id]/mark-sold
F-LIST-13	Save/favourite listings	Exists	Buyer	P0	/api/listings/save
F-LIST-14	Listing renewal (30-day expiry)	Exists	Seller	P1	/api/listings/[slug]/renew
F-LIST-15	Full-text search (tsvector)	Schema exists, needs wiring	Buyer	P1	listings.searchVector
F-LIST-16	Filter by category, condition, price, province	Exists	Buyer	P0	Browse query params
F-LIST-17	Listing moderation (pending -> approved)	Exists	Admin	P0	moderationStatusEnum
F-LIST-18	Saved-listing alerts (cron email)	Exists	Buyer	P2	/api/cron/saved-listing-alerts
F-LIST-19	Similar/related listings	Stubbed	Buyer	P2	Sprint 2
F-LIST-20	Report listing	**New**	Buyer/Admin	P1	Schema + UI

6.3 Business Directory

ID	Feature	Status	Persona	Priority	Code Reference
F-DIR-01	Browse directory (filter by type/province/city)	Exists	All	P0	/api/directory
F-DIR-02	Business detail page	Exists	Buyer	P0	BusinessDetail.tsx
F-DIR-03	Map view (Leaflet)	Exists	Buyer	P1	app/directory/MapComponent
F-DIR-04	Proximity search (lat/lng/radius)	Exists	Buyer	P1	/api/directory?lat&lng&nearbyKm
F-DIR-05	Self-serve business registration	Exists	Shop Owner	P0	/api/directory/register
F-DIR-06	Concierge registration (admin-assisted)	Exists	Shop Owner	P0	mode=concierge
F-DIR-07	Business claim via JWT token link	Exists	Shop Owner	P0	/api/directory/claim
F-DIR-08	3-touch outreach email sequence	Exists	Admin -> Shop	P0	email-templates touch1/2/3
F-DIR-09	Verification pipeline (pending/verified/suspended)	Exists	Admin	P0	businessStatusEnum
F-DIR-10	Business hours (JSON)	Schema exists	Shop Owner	P1	businesses.hours
F-DIR-	Brands stocked + services arrays	Exists	Shop Owner	P0	text[] columns

ID	Feature	Status	Persona	Priority	Code Reference
11					
F-DIR-12	WhatsApp contact button	Exists	Buyer	P0	BusinessDetail
F-DIR-13	Reviews/ratings	**New**	All	P2	New schema
F-DIR-14	Admin verification dashboard	Exists	Admin	P0	/admin/verifications
F-DIR-15	Boost tiers (Free/Starter/Pro/Anchor)	Exists	Shop Owner	P0	businesses.tier/boostTier

6.4 Cycling Routes

ID	Feature	Status	Persona	Priority	Code Reference
F-RT-01	Browse routes (filter by discipline, difficulty, distance, province)	Exists	All	P0	/api/routes
F-RT-02	Route detail with gallery, loops, reviews	Exists	All	P0	app/routes/[slug]
F-RT-03	Route map + GPX download	Partial	Buyer	P1	routes.gpxUrl
F-RT-04	Route loops with colour-coded difficulty	Exists	All	P1	route_loops table
F-RT-05	Reviews + conditions notes	Exists	All	P1	route_reviews
F-RT-06	Save route	Exists	All	P1	/api/routes/[slug]/save
F-RT-07	Proximity search	Exists	All	P1	?lat&lng&nearbyKm
F-RT-08	Admin route management (create/edit/images)	Exists	Admin	P0	/admin/routes/*
F-RT-09	Scrape integrations (Trailforks, Komoot, MTB Trails SA)	Exists	Admin	P1	src/db/scrapers/
F-RT-10	"My Routes" tab (user's submissions)	**New**	All	P2	Needs submitted_by index

6.5 Events

ID	Feature	Status	Persona	Priority	Code Reference
F-EV-01	Calendar + list + map views	Exists	All	P0	EventsCalendar, EventsMap
F-EV-02	8 event types (race/sportive/fun_ride/etc.)	Exists	All	P0	eventTypeEnum
F-EV-03	Event detail page	Exists	All	P0	app/events/[slug]
F-EV-04	Event submission form	Exists	Organiser	P0	/api/events/submit
F-EV-05	Organiser portal via token edit link	Exists	Organiser	P0	/api/events/manage/[token]
F-EV-06	Moderation workflow	Exists	Admin	P0	eventStatusEnum
F-EV-07	Entry fee + registration URL	Exists	Organiser	P0	entry_url, entry_fee
F-EV-08	Event boost (Featured/Headline tiers)	Exists	Organiser	P1	boostTier on events
F-EV-09	Filter by month/province/type	Exists	All	P0	Query params
F-EV-10	Organiser outreach emails	Exists	Admin	P1	email templates

6.6 Messaging

ID	Feature	Status	Persona	Priority	Code Reference
F-MSG-01	Buyer-seller direct messaging	Exists	Buyer/Seller	P0	/api/messages/*
F-MSG-02	Conversation threads	Exists	All	P0	/api/messages
F-MSG-03	Unread count badge	Exists	All	P0	/api/messages/unread-count
F-MSG-04	Start conversation from listing	Exists	Buyer	P0	/api/messages/start
F-MSG-05	Email notifications on new message	Exists	All	P1	email-templates
F-MSG-06	Rate limiting / spam protection	**New**	Admin	P1	Middleware
F-MSG-07	Report conversation	**New**	All	P2	New schema

6.7 Monetisation (Boosts & Payments)

ID	Feature	Status	Persona	Priority	Code Reference
F-PAY-01	Boost package catalogue	Exists	Seller/Shop	P0	/api/boosts/packages
F-PAY-02	4 boost types (bump, category_top, homepage, directory)	Exists	All	P0	boostTypeEnum
F-PAY-03	PayFast checkout + signature + IPN	Exists	Seller	P0	src/lib/payfast.ts
F-PAY-04	Boost expiry cron	Exists	System	P0	/api/cron/expire-boosts
F-PAY-05	Business tier pricing (R0/R149/R399/R999)	Exists	Shop Owner	P0	/pricing page
F-PAY-06	Event boost pricing (R0/R299/R799)	Exists	Organiser	P0	/pricing page
F-PAY-07	Admin payment reconciliation	Exists	Admin	P0	/admin/payfast
F-PAY-08	Refund workflow	Manual	Admin	P2	DB update
F-PAY-09	Stripe integration (international)	**New**	Future	P2 (Phase 2+)	lib/payments/stripe.ts
F-PAY-10	Country-aware gateway selection	**New**	System	P1	payment interface

6.8 News & Editorial

ID	Feature	Status	Persona	Priority	Code Reference
F-NEWS-01	Browse articles	Exists	All	P1	app/news
F-NEWS-02	Article detail page	Exists	All	P1	app/news/[slug]
F-NEWS-03	Submit article	Exists	All	P2	/api/news/submit
F-NEWS-04	Admin news management	Exists	Admin	P1	/admin/news
F-NEWS-05	Author byline / "My Articles"	**New**	All	P2	Needs author_id

6.9 Admin Platform

ID	Feature	Status	Persona	Priority	Code Reference
F-ADM-01	Dashboard (stats overview)	Exists	Admin	P0	/admin
F-ADM-02	User management + role assignment	Exists	Admin	P0	/admin/users
F-ADM-03	Listing moderation	Exists	Admin	P0	/admin/listings
F-ADM-04	Event moderation	Exists	Admin	P0	/admin/events
F-ADM-05	Directory moderation	Exists	Admin	P0	/admin/directory
F-ADM-06	Route management	Exists	Admin	P0	/admin/routes
F-ADM-07	Boost package CRUD	Exists	Admin	P0	/admin/boosts
F-ADM-08	PayFast payment monitoring	Exists	Admin	P0	/admin/payfast
F-ADM-09	Verification queue	Exists	Admin	P0	/admin/verifications
F-ADM-10	Email template preview	Exists	Admin	P1	/admin/email-templates
F-ADM-11	Theme customisation	Exists	Admin	P2	/admin/theme
F-ADM-12	SEO audit tools	Exists	Admin	P1	/admin/seo-audit
F-ADM-13	Analytics dashboard	Exists	Admin	P0	/admin/analytics
F-ADM-14	Site settings (SMTP, general)	Exists	Admin	P0	/admin/settings

ID	Feature	Status	Persona	Priority	Code Reference
F-ADM-15	**Admin Whiteboard (new)**	**New**	Admin	P1	/admin/whiteboard
F-ADM-16	Reports management	Exists	Admin	P2	/admin/reports

6.10 International Framework (New)

ID	Feature	Status	Priority	Spec
F-INTL-01	Country config system	**New**	P0	src/config/countries/[code].ts
F-INTL-02	Dynamic /[country]/ routing	**New**	P0	app/[country]/ segment
F-INTL-03	Currency abstraction	**New**	P0	formatPrice(cents, countryCode)
F-INTL-04	Region/province abstraction	**New**	P0	Country-specific regions
F-INTL-05	Phone format abstraction	**New**	P1	Country phoneFormat
F-INTL-06	Payment gateway interface	**New**	P0	lib/payments/interface.ts
F-INTL-07	Timezone abstraction	**New**	P1	Country timezone
F-INTL-08	country_code column on content tables	**New**	P0	Drizzle migration 0008
F-INTL-09	IP-based country auto-detect (root)	**New**	P1	middleware.ts
F-INTL-10	Country-aware sitemap	**New**	P1	app/[country]/sitemap.ts

6.11 Rebrand (New)

ID	Feature	Status	Priority	Detail
F-RB-01	All cyclemart references -> crankmart	**New**	P0	304+ locations (see REBRAND_INVENTORY.md)
F-RB-02	New logo + favicon set	**New**	P0	7 icon sizes
F-RB-03	New email templates (11)	**New**	P0	crankmart branding
F-RB-04	New social handles	**New**	P1	Secure @crankmart everywhere
F-RB-05	cyclemart.co.za 301 -> crankmart.com/za	**New**	P0	Vercel redirect
F-RB-06	crankmart.co.za 301 -> crankmart.com/za	**New**	P0	Vercel redirect

6.12 Out of Scope (Phase 1)

- Native mobile app (React Native / Expo) -- PWA only
- Multi-language translation -- English only
- AI pricing recommendations
- Integrated shipping/logistics
- Real-time chat (WebSockets)
- Push notifications
- Bike valuation tool
- Insurance partnerships
- Affiliate programme
- Video content / live streaming

Part 2B: User Stories & Acceptance Criteria

Critical P0 user stories with acceptance criteria (Gherkin-lite format). Full backlog lives in the admin whiteboard post-launch.

7. User Stories (P0)

7.1 Authentication

US-AUTH-01: Register with email

> As a new visitor, I want to register with email+password so that I can list or save items.

Acceptance criteria:

- GIVEN I'm on /register, WHEN I enter name, valid email, password (>=8 chars), province, AND click Register, THEN a user is created and I'm redirected to /account.
- AND I receive a welcome email within 60 seconds.
- GIVEN email already exists, WHEN I submit, THEN I see "Email already registered" and stay on page.
- GIVEN password < 8 chars, WHEN I submit, THEN I see inline validation error.

US-AUTH-02: Login with Google

> As a returning user, I want to login with Google so I don't need to remember a password.

Acceptance:

- GIVEN valid Google account, WHEN I click "Continue with Google", THEN I'm redirected to Google, then back to /account with active session.
- GIVEN first-time Google user, THEN a user record is created with role='buyer' and emailVerified=true.
- Session persists across tabs and survives page refresh.

US-AUTH-03: Reset password

> As a user who forgot my password, I want to reset it via email.

Acceptance:

- GIVEN I enter email on /forgot-password, THEN I receive a reset link within 60s.
- Link expires after 1 hour.
- GIVEN expired token, WHEN I use it, THEN I see "Link expired, request a new one".
- New password must be >= 8 chars.
- After reset, all existing sessions for that user are invalidated.

7.2 Selling

US-SELL-01: Create a listing (happy path)

> As a seller, I want to list my bike in under 5 minutes.

Acceptance:

- I can complete steps 1-4 without losing data if I navigate away (draft persists via localStorage + server).
- Step 1: category selected, saved to localStorage `crankmart-sell-category`.
- Step 2: title, condition required; all bike-spec fields optional; autosave every 1.5s.

- Step 3: 1-15 images, each <= 10MB, jpeg/png/webp/heic.
- Step 4: price (required), province (required), city (required); optional postal code, shipping.
- On Publish: listing created with status='active', moderationStatus='pending', 30-day expiry.
- I receive confirmation email with listing URL.

US-SELL-02: Duplicate detection

> As a seller, I don't want to accidentally create duplicate listings.

Acceptance:

- GIVEN I have an existing active listing with title similar (25-char match, case-insensitive), WHEN I publish a new one, THEN the API returns 409 with existing slug/title.
- I see a modal: "You have a similar listing. View existing, or confirm publish new?"
- Choosing "Publish anyway" sends `forceDuplicate: true` and publishes.

US-SELL-03: Mark as sold

> As a seller, I want to mark my listing as sold.

Acceptance:

- "Mark Sold" button visible only to seller on listing detail.
- On click, listing status changes to 'sold', soldAt timestamp set, removed from browse results.
- Buyer messages in existing conversations still accessible.

7.3 Buying

US-BUY-01: Browse and filter

> As a buyer, I want to find a hardtail MTB under R15,000 near me.

Acceptance:

- /browse loads with default filters.
- Apply filters: category=mtb, maxPrice=15000, province=gauteng.
- URL updates with query params (shareable).
- Listings render as single-column mobile, grid on desktop >= 900px.
- Infinite scroll loads next 24 per request.
- Empty state: "No listings match. Adjust filters or save this search."

US-BUY-02: Contact seller

> As a buyer, I want to message the seller without revealing my phone number.

Acceptance:

- "Contact Seller" button on listing detail requires login (redirects to /login with callback).
- Opens message composer, 1-2000 chars, attaches listingId.
- On send, a new conversation is created (or reuses existing) and seller receives email notification.
- Messages render in conversation thread with sender name, body, timestamp.

US-BUY-03: Save a listing

> As a buyer, I want to save listings to revisit later.

Acceptance:

- Save icon on listing card / detail page.
- Requires login (redirect if not).
- Toggle behaviour: POST /api/listings/save with listingId flips save state.
- Saved listings appear in /account under Saved tab with saved-at timestamp.
- Unsave removes from list immediately (optimistic UI).

7.4 Directory / Business

US-SHOP-01: Claim my business

> As a shop owner, I want to claim my existing directory listing via the token in my email.

Acceptance:

- Email link: crankmart.com/za/directory/claim?token=...
- Server validates token: exists, not expired (30-day TTL).
- If invalid/expired: show error + "Request new link" button.
- If valid: render prefilled form (business name read-only; phone/email/website/hours/description editable).
- POPIA consent checkbox required.
- On submit: phone or email required; business status='claimed', verified=true, consentAt=now, claimToken cleared.
- User account created (if new email) with role='shop_owner' and random password.
- Verification email sent.
- Redirect to /directory/[slug]?claimed=1 with success toast.

US-SHOP-02: Edit my shop

> As a shop owner, I want to update my business details.

Acceptance:

- /account/my-shop accessible only to role=shop_owner with a claimed business.
- Editable fields: name, description, phone, email, website, address, suburb, city, province, brands stocked (array), services (array), hours (JSON).
- Saves via PATCH /api/account/my-shop.
- Logo/cover upload via separate endpoints.
- Updates reflect on /directory/[slug] within 60s.

7.5 Events

US-EVT-01: Submit an event

> As an organiser, I want to list my event on the calendar.

Acceptance:

- /events/submit requires login.
- Fields: title (req), city (req), organiser email (req), start date (req), + optional description/venue/end date/entry URL/fee/distance/type/discipline/cover image.
- On submit: event created with status='pending_review'.
- Organiser receives confirmation + edit token link.
- Admin notified.
- Visible in admin moderation queue.

US-EVT-02: Edit my event via token link

> As an organiser without an account, I want to edit my event.

Acceptance:

- Email contains link: crankmart.com/za/events/manage/[token]
- Token validated against events.editToken; no login required.
- Editable: all submission fields except slug.
- Changes trigger re-moderation if major fields changed (title/date/venue).

7.6 Payments (Boosts)

US-PAY-01: Boost my listing

> As a seller, I want to pay to feature my listing on the homepage for 7 days.

Acceptance:

- "Boost" button on my listing detail -> /boost/select?listingId=...
- Boost package catalogue filtered by type (bump/category_top/homepage).
- Select package, click "Pay with PayFast".
- Boost record created with status='pending', amount from package.
- Form auto-submits to PayFast with MD5 signature.
- On PayFast success: user redirected to /boost/success.
- IPN webhook validates signature + IP; sets boost.status='active', updates listing.isFeatured, featuredExpiresAt.
- If cancelled/failed: boost.status='failed', listing unchanged.
- User sees boost state on listing + /account.

US-PAY-02: PayFast IPN idempotency

> As the platform, I must handle duplicate IPN webhooks without double-activating boosts.

Acceptance:

- GIVEN a boost already has status='active' with matching pf_payment_id, WHEN an IPN arrives, THEN return 200 "OK" and make no changes.
- Log duplicate for audit.

7.7 Admin

US-ADM-01: Moderate a listing

> As admin Zanele, I want to approve or reject pending listings.

Acceptance:

- /admin/listings?moderation=pending lists all pending items.
- Click row -> sidebar with listing detail + images.
- Approve: moderationStatus='approved'; listing appears in /browse.
- Reject: moderationStatus='rejected'; optional reason field; seller emailed.
- Flag: moderationStatus='flagged' for follow-up.
- Action logged with admin userId + timestamp.

US-ADM-02: Verify a business

> As admin, I want to verify a claimed business.

Acceptance:

- /admin/verifications shows 4-column pipeline (Pending / Outreach Sent / Claimed / Suspended).
- Move business between columns via action buttons.
- On verify: businesses.verified=true, verifiedAt=now; owner emailed.
- On suspend: businesses.status='suspended'; listing removed from /directory; owner notified.

US-ADM-03: Manage the whiteboard backlog

> As admin, I want a to-do/whiteboard to track operational tasks.

Acceptance:

- /admin/whiteboard renders a list/table of tasks.
- Fields: title, description, status (To Do/In Progress/Done/Blocked), priority (Critical/High/Medium/Low), category (Dev/Design/Content/Marketing/Infra/Other), assignee, due date, created date.
- Filter by status, priority, category.
- Inline edit status and priority.
- Persisted in `admin_todos` table.
- Only accessible to admin + superadmin roles.

Part 3: Flows, Data Model, Security, Privacy

8. Critical User Flows

8.1 Authentication Flow (Credentials)

```
User -> /login page
  |
  v
Enter email + password, submit
  |
  v
POST /api/auth/callback/credentials (NextAuth)
  |
  v
Server: lookup users.email (lowercase)
  |
  +--(no match)--> Return "Invalid credentials" -> UI error
  |
  v (match)
bcrypt.compare(password, passwordHash)
```

```
  |

  +--(mismatch)--> Return "Invalid credentials" -> UI error

  |

  v (match)

Issue JWT with { id, email, name, province, role }

  |

  v

Set httpOnly cookie

  |

  v

Hard navigate to callback URL or /account
```

Error states:

Error	User sees	HTTP
Invalid email format	Inline validation	N/A (client)
User not found	"Invalid credentials"	401
Wrong password	"Invalid credentials"	401
User banned (is_active=false)	"Account suspended, contact support"	403
Rate limit (5 attempts/5min)	"Too many attempts, try again in X min"	429

8.2 Payment Flow (PayFast)

```
User -> /boost/select?listingId=X
  |
  v
Fetches GET /api/boosts/packages
User selects package, clicks "Pay"
  |
  v
POST /api/boosts/initiate { packageId, listingId }
  |
  v
Server: validate ownership, create boost(status=pending)
  |
  v
Build PayFast payload + MD5 signature (see src/lib/payfast.ts:15-33)
  |
  v
Response: { checkoutUrl, fields, boostId }
  |
```

```
  v

Client auto-submits hidden form to PayFast

  |

  v

User pays on PayFast (external domain)

  |

  +--> return_url: /boost/success -> show confirmation (UI only)

  +--> cancel_url: /boost/cancel -> show cancel page

  |

  v

Meanwhile: PayFast -> POST /api/payments/payfast/itn (server-to-server)

  |

  v

Verify PayFast IP whitelist + MD5 signature

  |

  +--(invalid)--> 400/403, log, no state change

  |

  v (valid)
```

```
If payment_status='COMPLETE':

  - Transaction: update boost(status=active, startsAt, expiresAt, pf_payment_id)

  - Update listing/business/event (isFeatured=true, featuredExpiresAt)

If payment_status='FAILED'|'CANCELLED':

  - Update boost(status=failed)

  |

  v

Return 200 "OK" (idempotent: duplicate IPN = no-op)
```

Error states:

Error	System behaviour
Invalid IP	403, log to Sentry
Invalid signature	400, log
Boost not found	404, log
Already active (duplicate IPN)	200 OK, no change
Database transaction fail	500, log, PayFast retries

8.3 Sell Flow (4-Step Wizard)

```
/sell/step-1 (category)
  | [save to localStorage: crankmart-sell-category]

  v

/sell/step-2 (details)

  | [guard: requires step-1 key]

  | [load draft: GET /api/sell/draft || localStorage]

  | [autosave: POST /api/sell/draft every 1.5s]

  v

/sell/step-3 (photos)

  | [guard: requires step-1 + step-2 keys]

  | [upload: POST /api/sell/upload per file, append to list]

  | [localStorage: crankmart-sell-photos]

  v

/sell/step-4 (price + location)

  | [auth required: redirect to /login if unauth]

  | [load draft: GET /api/sell/draft]

  v

Submit -> POST /api/sell/publish
```

```
  |

  +--(duplicate detected)--> 409 + existingSlug -> Show modal "View existing or publis

  |

  v

Listing created (status=active, moderationStatus=pending, expiresAt=+30d)

  |

  v

DELETE /api/sell/draft (clear server draft)

Clear localStorage

Confirmation email sent

  |

  v

Redirect /sell/success -> /browse/[slug]
```

Error states:

Error	User sees
Missing required field	Inline validation
Image upload fails	Toast: "Upload failed, retry"; placeholder removed
Unauthenticated on step-4	Redirect to /login with callback
API 500 on publish	Toast: "Something went wrong, try again" + Sentry log

8.4 Business Claim Flow

```
Admin/System -> claim token generated (30-day TTL)
  |
  v
Touch 1 email -> shop owner clicks link
  |
  v
GET /za/directory/claim?token=X
  | [SSR: validate token against businesses.claimToken + claimTokenExpiresAt]
  |
  +--(invalid/expired)--> Show error + "Request new link"
  |
  v (valid)
Render ClaimForm with prefilled business data
User fills: name/phone/email/website/address/description + POPIA consent
  |
  v
POST /api/directory/claim
  |
```

```
  v

Re-validate token (prevents race)

Check phone OR email present

  |

  v

Find or create user (role=shop_owner, random password)

Update business: status=claimed, verified=true, claimedBy, consentAt

Clear: claimToken, claimTokenExpiresAt

  |

  v

Send verification email (shopVerifiedEmail)

Redirect /za/directory/[slug]?claimed=1
```

Error states:

Error	User sees
Token missing	404 page
Token expired	Error page + request-new link
No contact provided	Inline: "Phone or email required"
Consent not ticked	Submit disabled

---

9. Data Model

9.1 Core Tables (17)

See src/db/schema.ts for full Drizzle definitions. Summary:

Table	PK	Key Columns	Relations
users	uuid	email (unique), name, role, kycStatus, province, avatarUrl, passwordHash	-> listings, saves, messages
listing_categories	serial	slug (unique), parentId, name	<- listings
listings	uuid	slug (unique), sellerId -> users, categoryId, title, price (numeric), condition, status, moderationStatus, searchVector (tsvector), **country_code** (new)	<- listing_images, listing_saves, messages
listing_images	uuid	listingId, imageUrl, thumbUrl, displayOrder	
listing_saves	uuid	userId, listingId, createdAt	
conversations	uuid	listingId, buyerId, sellerId, lastMessageAt, unread counters	<- messages
messages	uuid	conversationId, senderId, body, isRead, createdAt	
businesses	uuid	slug (unique), name, businessType, status, verified, tier, boostTier, claimToken, claimedBy, searchVector, **country_code** (new)	
events	uuid	slug (unique), eventType, status, startDate, editToken, organiserUserId, boostTier, **country_code** (new)	
routes	uuid	slug (unique), discipline, difficulty, distanceKm, elevationM, lat, lng, status, submittedBy, **country_code** (new)	<- route_images, route_loops, route_reviews, route_saves
route_images	uuid	routeId, url, displayOrder, isPrimary	
route_loops	uuid	routeId, name, distanceKm, difficulty, category	
route_reviews	uuid	routeId, userId, rating, body, conditionsNote	
route_saves	uuid	userId, routeId	
scrape_runs	uuid	sourceName, startedAt, finishedAt, stats	
boost_packages	serial	type, name, priceCents, durationDays	<- boosts

Table	PK	Key Columns	Relations
boosts	uuid	userId, packageId, listingId OR directoryId OR eventId OR routeId OR newsId, status, startsAt, expiresAt, payfastPaymentId	
admin_todos (new)	uuid	title, description, status, priority, category, assignee, dueDate, createdAt	

9.2 Enums (16 + 1 new)

```
listing_condition: new, like_new, used, poor
listing_status: draft, active, sold, expired, removed, paused

user_role: buyer, seller, shop_owner, organiser, vendor, admin, superadmin

seller_type: individual, shop, brand

moderation_status: pending, approved, rejected, flagged

kyc_status: not_submitted, pending, approved, rejected

event_type: race, sportive, fun_ride, social_ride, training_camp, expo, club_event, ch

event_status: draft, pending_review, verified, cancelled, completed

boost_type: bump, category_top, homepage, directory

boost_status: pending, active, expired, failed, refunded

route_discipline: road, mtb, gravel, urban, bikepacking

route_difficulty: beginner, intermediate, advanced, expert

route_surface: tarmac, gravel, singletrack, mixed

route_status: pending, approved, rejected

business_type: shop, brand, service_center, tour_operator, event_organiser

business_status: pending, verified, suspended, claimed, removed

todo_status (new): to_do, in_progress, done, blocked

todo_priority (new): critical, high, medium, low
```

9.3 New Migration Required: 0008_country_code.sql

```
-- Add country_code to location-dependent tables
ALTER TABLE listings ADD COLUMN country_code VARCHAR(2) NOT NULL DEFAULT 'ZA';

ALTER TABLE businesses ADD COLUMN country_code VARCHAR(2) NOT NULL DEFAULT 'ZA';

ALTER TABLE routes ADD COLUMN country_code VARCHAR(2) NOT NULL DEFAULT 'ZA';

ALTER TABLE events ADD COLUMN country_code VARCHAR(2) NOT NULL DEFAULT 'ZA';

ALTER TABLE users ADD COLUMN country_code VARCHAR(2) NOT NULL DEFAULT 'ZA';


-- Indexes for country filtering

CREATE INDEX idx_listings_country ON listings(country_code);

CREATE INDEX idx_businesses_country ON businesses(country_code);

CREATE INDEX idx_routes_country ON routes(country_code);

CREATE INDEX idx_events_country ON events(country_code);


-- Admin whiteboard

CREATE TYPE todo_status AS ENUM ('to_do','in_progress','done','blocked');

CREATE TYPE todo_priority AS ENUM ('critical','high','medium','low');


CREATE TABLE admin_todos (

  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),

  title VARCHAR(255) NOT NULL,
```

```
  description TEXT,

  status todo_status NOT NULL DEFAULT 'to_do',

  priority todo_priority NOT NULL DEFAULT 'medium',

  category VARCHAR(50),

  assignee_id UUID REFERENCES users(id),

  due_date DATE,

  created_by UUID REFERENCES users(id) NOT NULL,

  created_at TIMESTAMP DEFAULT NOW(),

  updated_at TIMESTAMP DEFAULT NOW()

);
```

9.4 API Contracts

See `docs/API_CONTRACTS.md` for full request/response schemas of all 91+ endpoints.

Section 10: Security Threat Model

10.1 OWASP Top 10 Mapped to CrankMart

OWASP Risk	CrankMart Attack Surface	Mitigation
A01 Broken Access Control	Admin routes, listing ownership, conversation access	requireAdmin() middleware on all /api/admin/*; session userId checked against resource owner before every PATCH/DELETE; conversations locked to buyer/seller IDs
A02 Cryptographic Failures	Passwords at rest, PayFast signature, session tokens	bcrypt (cost=12) for passwords; PayFast MD5 signature validated server-side; NextAuth JWT signed with AUTH_SECRET (HS256, 256-bit random); HTTPS enforced via Vercel
A03 Injection	Listing search, directory search, slug params	Drizzle ORM parameterised queries throughout — no raw SQL interpolation; tsvector full-text search via Drizzle sql tagged template (auto-escaped)
A04 Insecure Design	Sell wizard multi-step, free-form description field, event submission	Server-side re-validation of all draft data at publish time; XSS-safe rendering (React escapes by default); admin moderation queue before listing goes live
A05 Security Misconfiguration	ENV vars, CORS, headers	All secrets in Vercel Environment Variables (never in code); Next.js default security headers; no CORS wildcard on mutation endpoints
A06 Vulnerable Components	npm dependency chain	Dependabot alerts enabled on repo; lock file committed; regular npm audit in CI
A07 Auth Failures	Login brute force, session fixation, password reset	Rate-limit login attempts (3 per IP per 15 min via middleware); NextAuth rotates session on sign-in; reset tokens are UUID v4, single-use, 1-hour TTL, hashed in DB
A08 Software & Data Integrity	PayFast webhook spoofing	IP whitelist (PayFast published CIDR blocks) + MD5 signature check; webhook body parsed before any DB write
A09 Logging Failures	Audit trail for admin actions, payment events	Structured logs via console.error captured by Vercel Log Drain; payment events logged to boosts table with full PayFast response payload

OWASP Risk	CrankMart Attack Surface	Mitigation
A10 SSRF	Directory concierge mode accepts website_url	URL validated against allowlist scheme (https only); no server-side URL fetching from user input; scraper runs in isolated cron, not triggered by user input

10.2 CrankMart-Specific Threat Scenarios

T-01: Fake Listing Spam

- **Attack:** Bot creates accounts and floods listings with spam/scam content.
- **Mitigations:** Email verification required before listing; admin moderation queue (status=pending to active); rate limit POST /api/sell/publish to 5/hour per user.

T-02: PayFast Replay Attack

- **Attack:** Attacker re-sends a valid ITN webhook to credit a boost multiple times.
- **Mitigations:** pf_payment_id stored in boosts table with UNIQUE constraint; duplicate ITN silently ignored (idempotent handler); m_payment_id maps to a single internal boostId.

T-03: Listing Hijack via IDOR

- **Attack:** User guesses another listing's UUID and PATCHes it.
- **Mitigations:** PATCH /api/listings/by-id/[id]/edit requires session.user.id === listing.sellerId; admin role required to override; UUID v4 (2^122 space) makes enumeration infeasible.

T-04: Avatar/Image Upload Abuse

- **Attack:** User uploads malicious file disguised as image.
- **Mitigations:** MIME type checked server-side (not just extension); max size enforced (10MB listings, 5MB avatars); images stored in Vercel Blob (isolated, no execution); filenames replaced with UUID on write.

T-05: Credential Stuffing on Login

- **Attack:** Attacker uses leaked credential list against /api/auth/credentials.
- **Mitigations:** NextAuth rate-limiting middleware (IP + email); bcrypt ensures slow comparison; no username enumeration on forgot-password (always 200).

T-06: Password Reset Token Theft

- **Attack:** Attacker intercepts or brute-forces reset token.
- **Mitigations:** Token = UUID v4 (2^122 space); stored as bcrypt hash in DB; expires in 1 hour; single-use (deleted on successful reset); sent only to verified email.

T-07: Admin Route Escalation

- **Attack:** Regular user calls /api/admin/* directly.
- **Mitigations:** requireAdmin() checks session.user.role === 'admin' on every admin route; role stored in JWT (not localStorage); role promoted only via direct DB update by platform owner.

T-08: XSS via Listing Content

- **Attack:** Seller injects script tags in description; displayed to buyers.
- **Mitigations:** React JSX renders text nodes (auto-escaped); no dangerouslySetInnerHTML on user content; rich text (if added) must use DOMPurify sanitiser.

T-09: Country Scope Bypass

- **Attack:** User from /za attempts to post listings under /au scope.
- **Mitigations:** country_code derived server-side from URL path segment (/za, /au), not from user-supplied payload; publish endpoint sets country_code from middleware-resolved locale.

T-10: Scraper Bot Abuse

- **Attack:** CrankMartBot user-agent mimicked to scrape or flood target sites.
- **Mitigations:** Scrapers run on server cron only; no public-facing endpoint triggers scraping; rate limits respected in scraper code; robots.txt respected.

10.3 Security Headers

```
// next.config.ts — headers()
const securityHeaders = [

  { key: 'X-DNS-Prefetch-Control', value: 'on' },

  { key: 'Strict-Transport-Security', value: 'max-age=63072000; includeSubDomains; pre

  { key: 'X-Frame-Options', value: 'SAMEORIGIN' },

  { key: 'X-Content-Type-Options', value: 'nosniff' },

  { key: 'Referrer-Policy', value: 'origin-when-cross-origin' },

  { key: 'Permissions-Policy', value: 'camera=(), microphone=(), geolocation=(self)' }

];
```

10.4 Dependency Security Policy

- **Lock file:** package-lock.json committed; CI fails on lock mismatch.
- **Audit:** npm audit --audit-level=high runs in GitHub Actions on every PR.
- **Dependabot:** Weekly dependency update PRs auto-opened.
- **No eval:** ESLint rule no-eval enforced; no dynamic require() with user input.

Section 11: Privacy & Compliance

11.1 Data Classification

Data Class	Examples	Storage	Retention
Public	Listing content, business profiles, route data	PostgreSQL + Blob	Indefinite (until deleted)
User PII	Name, email, province, avatar	PostgreSQL (encrypted at rest via Neon)	Until account deletion
Sensitive	Hashed passwords, reset tokens	PostgreSQL	Passwords: indefinite; tokens: 1h TTL
Payment	PayFast payment IDs (no card data)	PostgreSQL	7 years (financial records)
Logs	API request logs, error traces	Vercel Log Drain	30 days

CrankMart never stores raw card numbers, CVVs, or full banking details. All payment processing is delegated to PayFast (PCI-DSS Level 1 certified).

11.2 POPIA Compliance (South Africa — /za scope)

POPIA Requirement	CrankMart Implementation
Lawful basis for processing	Contract performance (listing, buying) + legitimate interest (platform safety)
Information officer	Designated on privacy@crankmart.co.za
Privacy notice	/privacy page; shown at registration
Data subject rights	Account deletion removes PII; listings anonymised; export (Phase 2)
Breach notification	Within 72 hours to Information Regulator if >100 subjects affected
Cross-border transfers	Data stored on Neon (AWS us-east-1); covered by contractual clauses
Children's data	No under-18 accounts; ToS requires 18+
Direct marketing	Opt-in email only; unsubscribe in every email footer

POPIA Operator agreements: Neon, Vercel, and Resend (email) are data operators with DPAs in place.

11.3 GDPR Readiness (/au and /nz scope — Phase 2)

GDPR Requirement	Status	Action Required
Lawful basis	Planned	Contract + legitimate interest basis documented
Cookie consent	Phase 2	Cookie banner with consent manager
Right to erasure	Partial	Account delete flow implemented; full cascading delete needed
Data portability	Not yet	Export endpoint: GET /api/account/export (Phase 2)
DPO designation	Phase 2	Required if processing at scale
Privacy by design	Ongoing	country_code isolation ensures AU data never mingles with ZA

11.4 Data Retention & Deletion

```
User requests deletion → POST /api/account/delete (Phase 2)
  ├─ Set users.deleted_at = NOW()

  ├─ Anonymise: users.email = deleted_{id}@crankmart.com, name = 'Deleted User'

  ├─ Nullify: avatar_url, phone, address fields

  ├─ Mark listings status = 'removed'

  ├─ Preserve: payment records (7-year legal hold), anonymised analytics

  └─ Queue: Blob avatar deletion (async job)
```

11.5 Cookies & Tracking

Cookie	Type	Purpose	TTL
next-auth.session-token	Essential	Auth session	30 days
next-auth.csrf-token	Essential	CSRF protection	Session
crankmart-locale	Functional	Country preference	1 year
Analytics (Phase 2)	Analytics	Usage metrics	Provider-dependent

No third-party advertising cookies. Analytics to be privacy-first (Plausible or self-hosted PostHog).

11.6 Email Compliance

- Every transactional email includes: sender identity, physical address, unsubscribe link.
- Marketing emails (Phase 2): double opt-in, list stored in DB, honour unsubscribe within 48h.
- SPF, DKIM, DMARC records configured for crankmart.com sending domain.
- Resend (SMTP provider) DPA signed.

Part 4: Testing, Migration & Operations

Section 12: Testing Strategy

12.1 Testing Pyramid

```
         /\
        /  \   E2E Tests (Playwright)

       /    \  Critical user flows: register, sell, buy contact, boost

      /------\

     /        \ Integration Tests (Jest + Supertest)

    /          \ API route handlers, DB queries, PayFast ITN

   /------------\

  /              \ Unit Tests (Vitest)

 /                \ Pure functions: formatPrice, slugify, country config, validators

/------------------\
```

12.2 Unit Tests

Scope: Pure functions, utilities, country config logic.

Module	Tests
src/lib/country-config.ts	getCountryConfig returns correct currency/region/gateway per country_code
src/lib/format.ts	formatPrice formats ZAR, AUD, NZD correctly; handles 0 and negative
src/lib/slugify.ts	Produces URL-safe slugs; handles special chars, duplicates
src/lib/validators.ts	Email, phone, price validators return correct errors
src/lib/payfast.ts	generateSignature produces correct MD5; verifyIp matches CIDR

Tool: Vitest (co-located `*.test.ts` files) **Target:** 80% coverage on src/lib/*

12.3 Integration Tests

Scope: API route handlers tested against a real Neon test branch. **Setup:**

```
// tests/setup.ts
beforeAll(async () => {

  await db.execute(sql SET search_path TO test );

  await runMigrations();

  await seedTestData(); // 3 users, 5 listings, 2 businesses

});

afterAll(async () => {

  await db.execute(sql DROP SCHEMA test CASCADE );

});
```

Key test suites:

Suite	Scenarios
Auth routes	Register → verify → login → session; forgot-password token lifecycle
Listings CRUD	Create draft → publish → edit → mark-sold → expire
Save/Unsave	Toggle save; saved list returns correct items
Messages	Start conversation; send/receive; unread count increments
Admin moderation	Approve listing; reject listing; role escalation blocked
PayFast ITN	Valid signature + IP accepted; replay rejected; bad sig 400
Country scope	/za listing not returned for /au query; country_code set correctly

12.4 End-to-End Tests (Playwright)

Critical paths (must pass before every deployment):

Flow	Steps
F-01 Register & Login	Navigate /register → fill form → submit → verify email → login
F-02 Sell a Bike	Login → /sell/step-1 → step-2 → step-3 (upload photo) → step-4 → publish → listing live
F-03 Contact Seller	Login as buyer → /browse/[slug] → Send Message → conversation created
F-04 Save Listing	Click heart → saved count increments → /account/saved shows listing
F-05 Business Directory	Browse /directory → filter by type → view business → claim flow
F-06 Boost Purchase	Login → /boost/select → select package → PayFast sandbox → ITN → boost active
F-07 Admin Moderate	Login as admin → /admin/listings → approve pending listing → listing goes live
F-08 Country Switch	Visit /au → filters show Australian states not SA provinces; currency AUD

Tool: Playwright with `@playwright/test` **Environment:** Staging (Vercel Preview) with PayFast sandbox

12.5 Performance Baselines

Metric	Target	Tool
LCP (browse page, cold)	< 2.5s	Vercel Speed Insights
LCP (listing detail, cold)	< 2.0s	Vercel Speed Insights
API /api/listings p95	< 300ms	Vercel Function logs
API /api/directory p95	< 400ms	Vercel Function logs
DB query p99 (tsvector search)	< 100ms	Neon query insights
Time To Interactive	< 3.5s	Lighthouse CI
Lighthouse score (all pages)	>= 85	Lighthouse CI

12.6 Accessibility

- WCAG 2.1 AA compliance target.
- axe-core automated scan in CI (zero critical violations gate).
- Manual keyboard navigation audit before each major release.
- Colour contrast ratio >= 4.5:1 for body text, >= 3:1 for large text.

12.7 CI/CD Pipeline

```
git push → GitHub Actions
  ├─ lint (ESLint + Prettier)

  ├─ type-check (tsc --noEmit)

  ├─ unit tests (Vitest)

  ├─ integration tests (Jest + Neon test branch)

  ├─ npm audit --audit-level=high

  └─ PASS → Vercel Preview Deploy

              └─ E2E tests (Playwright on Preview URL)

                  └─ PASS → Promote to Production
```

Section 13: Migration Runbook

13.1 Overview

Migration from CycleMart (VelocityFibre/cyclemart) to CrankMart (Lewhof/crankmart). No live traffic yet — this is a greenfield rebrand, not a live system cutover.

13.2 Pre-Migration Checklist

- ☐ crankmart.com DNS configured; Vercel project linked
- ☐ crankmart.co.za 301 redirect to crankmart.com/za configured
- ☐ Neon project created; connection string in Vercel env
- ☐ AUTH_SECRET generated (openssl rand -base64 32)
- ☐ RESEND_API_KEY set; from-address verified on crankmart.com
- ☐ PAYFAST_MERCHANT_ID and PAYFAST_MERCHANT_KEY confirmed (24040660)
- ☐ Vercel Blob token set; old nginx /uploads/ paths documented

☐ All rebrand find-replace completed (see docs/REBRAND_INVENTORY.md)

☐ package.json name updated to "crankmart"

☐ New brand assets: logo, favicon, OG image uploaded to /public

13.3 Database Migration Steps

```
# Step 1: Run schema migrations in order
npm run db:migrate

Applies: 0001 through 0008_country_code.

Step 2: Verify schema

npm run db:studio  # Inspect tables in Drizzle Studio

Step 3: Seed reference data (categories,

npx tsx src/db/seed.ts

Step 4: Import production data from Cycl

Export from cyclemart Neon → import to c

pg_dump cyclemart_db | psql crankmart_db

Then: UPDATE listings SET country_code =
```

13.4 Rebrand Execution Order

```
1. package.json + package-lock.json (name field)
next.config.ts (image hostnames)

app/layout.tsx (schema.org, OG, social handles)

app/sitemap.ts + app/robots.ts + public/robots.txt

localStorage keys (all sell/step-*.tsx files)

Email templates (src/lib/email-templates.ts)

Email sender addresses (src/lib/email.ts + API routes)

Scraper user-agents (src/db/scrapers/*)

Storage paths → replace with Vercel Blob URLs

User-facing brand text (ListingDetail.tsx, FAQ, Terms, Privacy)

Social media handles (layout.tsx, llms.txt)

Seed files (test data emails only — not needed in production)
```

13.5 Image Migration (nginx → Vercel Blob)

```
// scripts/migrate-images.ts
// Run once to move all /uploads/* files to Vercel Blob

import { put } from '@vercel/blob';

import fs from 'fs';

import path from 'path';


const UPLOAD_DIR = '/home/velo/storage/cyclemart/uploads';

const categories = ['directory', 'avatars', 'listings'];


for (const cat of categories) {

  const dir = path.join(UPLOAD_DIR, cat);

  const files = fs.readdirSync(dir);

  for (const file of files) {

    const buffer = fs.readFileSync(path.join(dir, file));

    const blob = await put( ${cat}/${file} , buffer, { access: 'public' });

    // Update DB: replace old path with blob.url

    await db.execute(sql

      UPDATE listing_images

      SET image_url = ${blob.url}
```

```
      WHERE image_url LIKE ${ %${file} }

     );

  }

}
```

13.6 Rollback Plan

Scenario	Rollback Action
DB migration failure	`npm run db:rollback` (Drizzle down migrations); restore from Neon branch snapshot
Image migration failure	Old nginx server still accessible; revert DB image_url updates; re-run after fix
Vercel deployment failure	Instant rollback in Vercel dashboard → previous deployment
DNS misconfiguration	Revert DNS records in registrar; propagation < 5 min on Vercel
PayFast ITN not received	Check Vercel function logs; test with PayFast sandbox; verify IP whitelist includes Vercel IPs

Neon Branch Strategy for safe migration:

```
main (production) ──► create branch: migration-test
                        └─ run all migrations

                        └─ run seed scripts

                        └─ verify with Drizzle Studio

                        └─ PASS → merge to main branch
```

13.7 Go-Live Verification

After deployment to production:

- ☐ Home page loads on crankmart.com/za
- ☐ crankmart.co.za redirects to crankmart.com/za (301)
- ☐ Register flow: create account, receive email (check From address)
- ☐ Sell flow: publish test listing; appears in /browse
- ☐ PayFast sandbox boost: complete payment, boost activates
- ☐ Admin panel accessible at /admin (admin user seeded)
- ☐ robots.txt and sitemap.xml return correct crankmart.com URLs
- ☐ Vercel Speed Insights: LCP < 2.5s on browse page
- ☐ No console errors in browser DevTools

Section 14: Monitoring & Alerting

14.1 Observability Stack

Layer	Tool	What It Monitors
Infrastructure	Vercel Dashboard	Function invocations, errors, duration, bandwidth
Database	Neon Dashboard	Query duration, connection pool, storage, branches
Errors	Vercel Log Drain + Sentry (Phase 2)	Uncaught exceptions, 5xx responses
Performance	Vercel Speed Insights	LCP, FID, CLS per page, per country
Uptime	Better Uptime (Phase 2)	/api/health endpoint every 60s; SMS alert on down
Payments	PayFast Merchant Dashboard	Transaction history, failures, refunds

14.2 Health Check Endpoint

```
// app/api/health/route.ts
export async function GET() {

  const checks = {

    db: false,

    timestamp: new Date().toISOString(),

    version: process.env.npm_package_version,

  };

  try {

    await db.execute(sql SELECT 1 );

    checks.db = true;

  } catch {}

  const status = checks.db ? 200 : 503;

  return Response.json(checks, { status });

}
```

14.3 Alert Thresholds

Signal	Threshold	Action
5xx error rate	> 1% over 5 min	Vercel Slack alert
Function duration p99	> 10s	Investigate + scale
DB connection saturation	> 80% pool	Neon auto-scale kicks in
Neon storage	> 80% of plan	Upgrade plan
Failed PayFast ITN	Any	Slack alert + manual review
Cron job failure	Any	Vercel cron dashboard + email

14.4 Cron Job Schedule

Cron	Schedule	Purpose
/api/cron/expire-listings	Daily 00:00 UTC	Mark listings past expiresAt as expired
/api/cron/expire-boosts	Daily 00:05 UTC	Deactivate boosts past expiresAt
/api/cron/saved-listing-alerts	Daily 08:00 UTC	Email users about saved listing updates

Configured in `vercel.json`:

```
{
  "crons": [

    { "path": "/api/cron/expire-listings", "schedule": "0 0   *" },

    { "path": "/api/cron/expire-boosts", "schedule": "5 0   *" },

    { "path": "/api/cron/saved-listing-alerts", "schedule": "0 8   *" }

  ]

}
```

Section 15: Feature Flags & Phase Rollout

15.1 Phase Gate Model

Features are gated by environment variable flags, not code branches. This allows gradual rollout without code deploys.

Flag	Default	Controls
FEATURE_AU_LOCALE	false	/au route group enabled
FEATURE_NZ_LOCALE	false	/nz route group enabled
FEATURE_STRIPE	false	Stripe payment option shown
FEATURE_GOOGLE_OAUTH	true	Google sign-in button visible
FEATURE_ROUTES_MODULE	true	Routes section enabled
FEATURE_BOOSTS	true	Boost purchase flow enabled
FEATURE_DIRECTORY_CLAIM	true	Business claim flow enabled
FEATURE_USER_EXPORT	false	Account data export (GDPR)
NEXT_PUBLIC_MAINTENANCE	false	Maintenance mode page shown

15.2 Phase Delivery Summary

Phase	Scope	Trigger
Phase 1 (MVP)	CrankMart /za fully operational; all CycleMart features rebranded	Launch
Phase 2 (Growth)	/au live; Stripe; Google OAuth; user export; Sentry; email marketing	3 months post-launch
Phase 3 (Scale)	/nz; mobile app (React Native); affiliate programme; API partner access	6-12 months

Section 16: Risk Register

ID	Risk	Likelihood	Impact	Mitigation
R-01	PayFast ITN IP range changes silently	Low	High	Monitor PayFast developer changelog; add IP update to quarterly ops checklist
R-02	Neon cold-start latency spikes during low traffic	Medium	Medium	Enable Neon connection pooling (PgBouncer); set min pool size = 1
R-03	Image upload Blob quota exceeded	Low	Medium	Monitor Vercel Blob usage dashboard; set 80% alert; upgrade plan ahead
R-04	NextAuth v5 breaking change in patch	Low	High	Pin exact NextAuth version; test upgrades in staging branch first
R-05	Listing spam from fake accounts	Medium	High	Email verification gate; admin moderation queue; rate limits on publish
R-06	Vercel function timeout on large DB seeds	Low	Low	Seeds run locally or in separate Neon branch; not in prod cron
R-07	crankmart.co.za 301 redirect not set correctly	Medium	High	Test redirect on go-live checklist; confirm 301 (not 302) in curl -I
R-08	tsvector index not updated after bulk insert	Low	Medium	Verify triggers on listings, routes tables; run REINDEX if search degrades
R-09	Country config returns wrong currency for new locale	Low	High	Unit test getCountryConfig for every supported country_code
R-10	SMTP deliverability issues on new crankmart.com domain	Medium	High	Warm up sending domain; SPF/DKIM/DMARC configured before go-live; monitor bounce rate

Section 17: Dependency Map

17.1 External Services

Service	Purpose	Failure Mode	Fallback
Neon PostgreSQL	Primary database	All reads/writes fail	Read-only cached responses (Phase 2)
Vercel Blob	Image storage	Image uploads fail	Show placeholder; retry upload
Resend	Transactional email	Emails not sent	Silent fail; log; retry via queue (Phase 2)
PayFast	Payment gateway	Boost purchases fail	Show error; no charge; retry
Google OAuth	Social login	Google login unavailable	Credentials login still works
Vercel CDN	Page delivery	Site unavailable	Vercel SLA 99.99%
GitHub Actions	CI/CD	Deployments blocked	Manual deploy via Vercel CLI

17.2 Internal Module Dependencies

```
app/ pages
  └─ src/lib/country-config.ts     ← All locale-aware components

  └─ src/lib/auth.ts               ← All protected routes

  └─ src/lib/email.ts              ← Auth routes (reset, verify)

       └─ src/lib/email-templates.ts

  └─ src/db/schema.ts              ← All API routes

       └─ src/db/index.ts (Neon connection)

  └─ src/lib/payfast.ts            ← Boost payment routes

  └─ src/lib/utils.ts              ← Universal (format, slugify)
```

17.3 Key Package Versions (Pinned)

Package	Version	Risk if Updated
next	15.x	App Router API changes
next-auth	5.x	Session/JWT schema changes
drizzle-orm	0.3x	Query API changes
@vercel/blob	latest	Upload API changes
react	19.x	Concurrent features
tailwindcss	4.x	Config/utility changes

Section 18: Glossary

Term	Definition
CrankMart	The rebranded, international version of CycleMart. Domain: crankmart.com
CycleMart	The original SA cycling marketplace (VelocityFibre/cyclemart). Source codebase.
CDDP	CTO Deliberative Development Protocol — 8-step mandatory workflow before any build
country_code	ISO 3166-1 alpha-2 code (ZA, AU, NZ) used to scope all content and config
Country Config	The countryConfig map in src/lib/country-config.ts; returns currency, regions, payment gateway, timezone per country
Locale	A country-specific URL path segment: /za, /au, /nz
Boost	A paid promotion that increases listing or business visibility in search results
ITN	Instant Transaction Notification — PayFast's webhook that confirms payment completion
priceCents	All monetary values stored as integers in the smallest currency unit (cents for ZAR/AUD/NZD)
Drizzle ORM	TypeScript ORM used for all DB queries; provides type-safe parameterised queries
Neon	Serverless PostgreSQL provider; supports branching for safe migrations
Vercel Blob	Vercel's object storage for images; replaces nginx /uploads/ filesystem
tsvector	PostgreSQL full-text search type; used for listing and route search
PRD	Product Requirements Document — this document
POPIA	Protection of Personal Information Act — SA data privacy law
GDPR	General Data Protection Regulation — EU data privacy law (applies for /au, /nz scope)
Sell Wizard	4-step listing creation flow: category → details → photos → pricing/location
Admin Todo	Internal admin task/whiteboard item stored in admin_todos table
Concierge Mode	Directory registration mode where CrankMart team builds the listing on behalf of the business
Phase 1	MVP: CrankMart /za fully live with all CycleMart features rebranded
Phase 2	/au live, Stripe, Google OAuth, GDPR export, marketing email

Term	Definition
Phase 3	/nz, mobile app, affiliate programme, API partner access

---

Document version: 2.0 | Generated: 2026-04-12 | Authors: Lew Hofmeyr (COO) + Claude Code (CTO)